How Private Is Your Browsing? Detecting GDPR Violations Through Robust Natural Language Processing and Thorough Static Program Analysis Techniques

Gary Song
University of California, Los Angeles

Joshua Zhu
University of California, Los Angeles

Andrew Kuai
University of California, Los Angeles

Ben Chen
University of California, Los Angeles

Savannah Alanis
University of California, Los Angeles

***Abstract*—In the current age of the internet, online users are becoming increasingly cautious of the use of their private information. As a protective measure, the European Union (EU) instated the General Data Protection Regulation (GDPR) to protect the privacy of its citizens. However, many websites still do not follow the regulations listed in GDPR. We present a system that can thoroughly check websites using WordPress for GDPR violations through static program analysis, while also being able to check other websites for violations in the privacy policy through our natural language processing (NLP) model. This system improves on previous findings by using the website's URL to automate the process of gathering the data needed for analysis, which we accomplish with web scraping techniques. Finally, we present our NLP model with an accuracy of 80% that utilized transformers and transfer learning. This paper also gives various methods to apply and improve the system presented in this paper.**

I. Introduction

The General Data Protection Regulation (GDPR) is an EU law designed to protect personal data that went into effect on May 25, 2018. The law places restrictions on the collection and storage of "personal data" – any information that can identify a person. According to the GDPR, organizations who process this data must do so in accordance with seven principles outlined in the GDPR: lawfulness, fairness, and transparency; purpose limitation; data minimization; accuracy; storage limitation; integrity and confidentiality (security); and accountability. [1] Even though GDPR is an EU law, it applies internationally to organizations that offer goods to or process the personal data of EU citizens or residents. Thus, it is important to both users and organizations that websites comply with GDPR, for privacy and legal purposes.

This paper explores a method on automatically checking a website's GDPR compliance through an integration of methods given only the URL of the website. Our work automates the retrieval of the privacy policy and plugin code given the website's URL, making use easier for the user. We then analyze the privacy policy of the website through the use of our own NLP model that we train to check for any GDPR violations for the user. We also present a method that is able to check the plugin code for websites using WordPress, which allows us to analyze not only the client-side of the website but the server side as well. Our aim is to use these methods to build a program that is both robust and thorough.

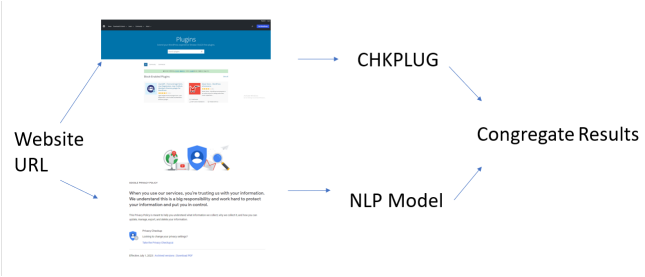

Fig. 1. Overview of our system utilizing both NLP models and static program analysis using a photo from https://policies.google.com/privacy?hl=en-US and https://wordpress.org/plugins/

We choose to analyze privacy policies since all websites are required to have a privacy policy for the user. [2] This allows us to robustly check all websites for privacy violations. A large number of websites are also developed using WordPress (a tool that can help build a website), specifically around 43%. [3] When developing a website with WordPress, users may use predeveloped plugins to construct their website. The source code for these plugins is publically available at https://wordpress.org/plugins/, which allows us to analyze both the client-side and server-side code. [4] Given the widespread use of WordPress, we believe it to be a useful vector for analysis.

To our knowledge, there are no other programs that integrate program analysis with NLP methods. Some Chrome extensions will only look at the privacy policy of a website. [5]

979-8-3503-0965-2/23/$31.00 ©2023 IEEE

Other works are only able to provide one of these methods. [6] [4] These works also require the manual input of data, while our work seeks to automate these processes.

II. Background and Related Work

In this section, we present previous work that tackles challenges similar to ours and how our project differs from previous research. We then give background information on how our project works

A. Related Work

a) GDPR analysis: Analysis of GDPR compliance is currently a popular topic in research. Researchers have sought to develop models that detect violations in a website's privacy policy using NLP techniques. [6] There have been some websites online that can detect whether a website's cookie usage is GDPR compliant or not, such as https://2gdpr.com/. Other researchers have attempted to detect GDPR violations in programs through static analysis. [4] There have also been works discussing more general privacy policy issues, such as contradictions within the privacy policy and inconsistencies between the privacy policy and the data flow. [7] [8]

These works mainly focus on one area when doing analysis, and thus give up the benefits of other methods. For example, analyzing the WordPress plugins of a website will not be able to have as much coverage as a method that analyzes a website's privacy policy. Thus, our work aims to integrate these methods to have a program that can provide deep program analysis of a website while also being able to safely analyze a majority of websites. We also provide ways to automate extracting the required information from the website rather than providing it manually.

B. Background

In this section, we describe the background used in this paper

1) GDPR: GDPR has specific policies for handling a person's data. There are 18 main categories of information on how personal data is handled that must be explained in a website's privacy policy, such as who is receiving a person's data. [6] More information can be found in the GDPR policy. [9] Our NLP model aims to accurately classify areas of the privacy policy to check which categories are included in the privacy policy.

2) Transformers: Transformers are a relatively new deep-learning architecture that greatly improves on previous Seq2Seq models. [10]. The main feature that Transformers provide is their ability to bring special attention to different parts of the incoming sequence, thus more heavily weighting more important parts of the sequence. It does this by utilizing its attention functions. An example of an attention function can take in three arguments: Q, K, V, and calculate the attention as follows

$$\text{Attention}(Q, K, V) = \text{softmax}\left(\frac{QK^T}{\sqrt{d_k}}\right)V$$

where Q is the set of queries and K and V represent the keys and values. The attention can thus be thought of as a scalar multiple of the value of a term from the sequence.

3) Transfer Learning: Transfer learning is the technique of using an already trained model on a new problem, which allows the knowledge from the previous task to be reused in the new problem. With transformers specifically, there are many transformers trained thoroughly on large amounts of text that are available for others to use. Through the process of fine-tuning, one can leverage existing powerful transformers and with some training on one's data, adapt it to their task. This requires much less time and data than if one were to train a transformer from scratch.

Other than saving time, transfer learning can possibly improve on the accuracy of models. The basis of this idea can possibly be found in human learning, as can be found in psychologist C.H. Judd's theory of transfer of learning. He claimed that while previous learning may provide a hindrance to learning new topics, in some cases it can instead accelerate and improve the person's learning. For example, one might intuitively think that someone who learned to play the piano may be able to quickly pick up on playing the organ. Research has shown the validity of this approach and that it is an important topic for future research. [11]

III. Methodology/Design

In this section, we describe the design and methods used in our program.

A. WordPress plugin analysis

a) Plugin scraping: We first must parse through a website to scrape out the plugins that it is using, given that it was built using WordPress. We use the website's URL to retrieve its source code. If a website is using WordPress, the website's source code will contain indicators such as containing links to files from WordPress. [12] Thus, we used a web crawler to parse through the website's HTML code to see any references to WordPress plugins. Once we found a reference to a plugin's file, we parsed through the directory of the file to get the name of the plugin.

b) Downloading files: Once we have the names of the plugins that were used, we can search for and download the files for analysis. We first check *https://wordpress.org/plugins/plugin-name* to see if the plugin exists. If the web page does not exist, we instead search for the plugin using *https://wordpress.org/search/plugin-name* to find the website that contains the plugin's code. We can automate this process using Selenium. [13]

Once we find the plugin's web page, we can then use BeautifulSoup [14] to look for the link to the plugin's files. We then use Python to download and unzip the files into their directory.

c) Analyzing plugin files: We utilize CHKPLUG [4] to analyze the plugin for any GDPR violations. CHKPLUG utilizes Cross-CPGs to analyze the flow of user data throughout the program, which allows for a thorough examination of

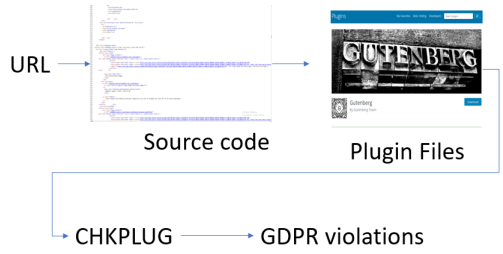

Fig. 2. Overview of the processes of extracting and analyzing the WordPress plugins of a website, using a screenshot from the source code of https://time.com/ which is a popular website that uses WordPress

both the client-side and server-side code. We use Python to automate the usage of CHKPLUG onto the plugins.

B. Privacy policy analysis

a) Extracting the privacy policy: We first must extract the privacy policy of the website that we wish to analyze. To do so, we first get the domain name of the current website from its URL. We then use Google's Custom Search JSON API to search for the web page containing the privacy policy. We make a search query using the concatenation of the website's domain name with the term "privacy policy". We also take advantage of the Custom Search API by filtering out results that do not contain the exact phrase "Privacy Policy", which allows us to filter out extraneous websites. Once we get the website containing the privacy policy, we can request the HTML for the webpage. With the help of a tool provided by Andow [7] we can extract out the policy from the HTML as plaintext.

b) Language Model Development: To create our model, we used a pre-trained transformer based on the DistilBERT architecture so that we could take advantage of the technique of transfer learning. We then fine-tuned the model for our purposes through the use of a public data set provided by Al Rahat [6]. This data set allowed us to train our model to classify sentences based on what categories of GDPR's user privacy policies they cover.

c) Policy Evaluation: After extracting the privacy policy, we split it up by sentence so that we could process each sentence individually. The sentences are then preprocessed by a tokenizer, which encodes them so that they may be processed by the transformer. The transformer then returns a score that measures the relevance of the sentence to each category of GDPR that we are observing. Once we finish analyzing the policy, we can look at all our results to see which areas of GDPR were covered and which were neglected. The effectiveness and accuracy of our trained model are discussed in our evaluation section.

C. Integrating Data

We now describe how we combine our data from our two methods. From our analysis of WordPress plugins, we can present any GDPR violations that occurred in the code. Conversely, our NLP model detects areas of the privacy policy

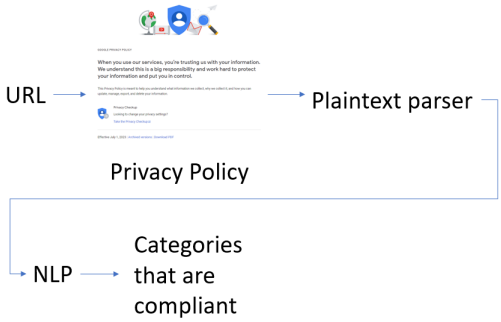

Fig. 3. Overview of the flow of processes used when extracting and analyzing the privacy policy

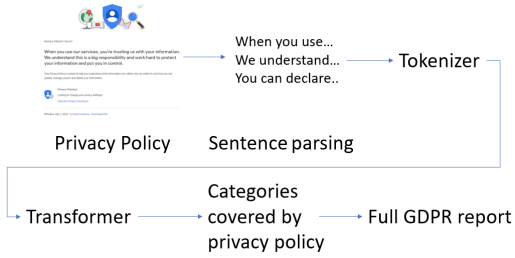

Fig. 4. Detailed look into how we feed data into our NLP model

that are compliant with GDPR. We can then mark the areas that were not detected in the privacy policy as possible violations. Combining these data, we have a result that shows in what areas the website complies with GDPR and in what areas it may violate GDPR.

IV. Evaluation

In this section, we present the evaluation of our NLP model.

The metrics for accuracy in a multilabel classification problem differ from those used in ordinary multiclass classification, as in multilabel classification there is the notion of "partial" correctness for a prediction. We present the multilabel classification metrics used by Sorower [15] as follows.

Exact Match Ratio: Exact Match Ratio is the measure of predictions that accurately predict every single label for a single data point, where the "labels" refer to which categories that the data point falls in. For example, if a data point satisfies 2 GDPR requirements and no others, it has 2 labels. This metric ignores any partial correctness.

Accuracy: The accuracy of a single data point is the proportion of correctly predicted labels to the combined total number of labels of both predicted and actual labels, without double counting overlapping labels. Overall accuracy is the average accuracy of all data points.

Precision: Precision is the proportion of predicted correct labels to the total number of actual labels, averaged over all instances.

Recall: Recall is the proportion of predicted correct labels to the total number of predicted labels, averaged over all

Exact Match Ratio	Accuracy	Precision	Recall	F_1 Score
0.781	0.801	0.804	0.901	0.807

Fig. 5. Measure of accuracy for our model

instances. If the model predicts no labels for a data point, we treat it as a completely accurate recall.

F_1 **Score:** F_1 score maintains the same definition as the harmonic mean of precision and recall.

Due to the relatively low amount of data, we used 95% of the data as training data and the remaining 5% as test data. Shown in **Figure 5** are the exact match ratio, accuracy, precision, recall, and F_1 score of our model on the test data.

It is unsurprising that the Exact Match Ratio is lower than the rest of the metrics, as it has a harsher condition. The fact that it is fairly close to them means that the model is doing fairly well. The high recall score compared to the lower precision score suggests that our model leans more on the side of not classifying GDPR requirements over incorrectly assigning classifications that aren't actually met.

V. Conclusion

In our work, we introduce a system that can robustly and thoroughly detect GDPR violations in a website with only a website's URL given as user input. However, the thoroughness comes from the ability to analyze the code used in the site's WordPress plugins. This means that approximately 57% of websites do not benefit from this analysis. [3] Even for the sites that do, it does not check for parts of the website that do not utilize plugins. To improve on this, we may consider other areas of a website that may be subject to program analysis.

For improving our NLP model, the metrics could be improved with a larger architecture for our transformer, though that would also come with the drawback of a longer computation time for training and making predictions. In addition, our NLP classification model was only trained on privacy policies written in English. However, since GDPR is a regulation held by the EU it is important to expand to all languages spoken in the EU, rather than just English.

It is also evident from our evaluation that while our model is passable, it is still rather suboptimal. Continued training on our model would yield diminishing returns and could also lead to overfitting, so this may be the limit for our current architecture. We may wish to consider to different pre-trained Transformer to apply in the future, or a different approach altogether. For example, convolutional neural network approaches have proven to be effective [6].

Given that our system is entirely automated after one input of a website's URL, this program can be compacted into a browser extension that allows users to easily check for violations in the websites that they are browsing. We intend to use our program to implement such an extension in the future. We also intend to open-source our code once we publish the extension.

Acknowledgment

We would like to thank Faysal Hossain Shezan for his mentorship in our project. We would also like to acknowledge Tamjid Al Rahat for publishing his data set online for others to use. We would also like to thank our friends and peers at ACM Cyber at UCLA for their support and help!

References

[1] 2023. [Online]. Available: https://gdpr.eu/what-is-gdpr/

[2] 2023. [Online]. Available: https://www.termsfeed.com/blog/privacy-policy-mandatory-law/

[3] 2023. [Online]. Available: https://colorlib.com/wp/wordpress-statistics/

[4] F. H. Shezan, Z. Su, M. Kang, N. Phair, P. W. Thomas, M. van Dam, Y. Cao, and Y. Tian, "Chkplug: Checking gdpr compliance of wordpress plugins via cross-language code property graph." in *NDSS*, 2023.

[5] rolfba, "Consent-o-matic," Chrome Web Store, 2023. [Online]. Available: https://chrome.google.com/webstore/detail/consent-o-matic/mdjildafknihdffpkfmmpnpoiajfjnjd

[6] T. A. Rahat, M. Long, and Y. Tian, "Is your policy compliant? a deep learning-based empirical study of privacy policies' compliance with gdpr," in *Proceedings of the 21st Workshop on Privacy in the Electronic Society*, ser. WPES'22. New York, NY, USA: Association for Computing Machinery, 2022, p. 89–102. [Online]. Available: https://doi.org/10.1145/3559613.3563195

[7] B. Andow, S. Y. Mahmud, W. Wang, J. Whitaker, W. Enck, B. Reaves, K. Singh, and T. Xie, "PolicyLint: Investigating internal privacy policy contradictions on google play," in *28th USENIX Security Symposium (USENIX Security 19)*. Santa Clara, CA: USENIX Association, Aug. 2019, pp. 585–602. [Online]. Available: https://www.usenix.org/conference/usenixsecurity19/presentation/andow

[8] B. Andow, S. Y. Mahmud, J. Whitaker, W. Enck, B. Reaves, K. Singh, and S. Egelman, "Actions speak louder than words: Entity-Sensitive privacy policy and data flow analysis with PoliCheck," in *29th USENIX Security Symposium (USENIX Security 20)*. USENIX Association, Aug. 2020, pp. 985–1002. [Online]. Available: https://www.usenix.org/conference/usenixsecurity20/presentation/andow

[9] 2023. [Online]. Available: https://gdpr-info.eu/art-12-gdpr/

[10] A. Vaswani, N. Shazeer, N. Parmar, J. Uszkoreit, L. Jones, A. N. Gomez, L. Kaiser, and I. Polosukhin, "Attention is all you need," 2023.

[11] F. Zhuang, Z. Qi, K. Duan, D. Xi, Y. Zhu, H. Zhu, H. Xiong, and Q. He, "A comprehensive survey on transfer learning," 2020.

[12] 2023. [Online]. Available: https://blog.hubspot.com/website/8-best-tools-to-detect-wordpress-theme-and-plugins

[13] 2023, selenium web browser. [Online]. Available: https://www.selenium.dev/

[14] 2023, beautifulSoup webscraper. [Online]. Available: https://www.crummy.com/software/BeautifulSoup/

[15] M. S. Sorower, "A literature survey on algorithms for multi-label learning," 2010. [Online]. Available: https://api.semanticscholar.org/CorpusID:13222909